

Stack 07 audit candidate — ERC-7730 and streamed EIP-712

1. Identity and finite scope

Owner: Codex /root, vault agent-2. Main-worktree claim: docs/release/audit-claims/715-07/OWNER.md. Canonical master/SOP hashes are preserved in the validation bundle's canonical-doc-hashes.txt. Initial master hash was 67caefef586d17212874072019de8d434e16a79b4edbc52c6e1b7d338d0b87a1. The main documents were reread before this freeze.

Immediate candidate predecessor: Stack 06 PR #859, audit/715-stack06-agent1-reconcile at efdeb678bc33c616cf8048fb5773548f0da96fa7. Frozen implementation head: 92774faeb. Inventory generation predecessor: 2ea62657693413405e3730fb13c40c1db961191e. Final containing head and hosted CI result belong in PR #837's description, because this report cannot embed its own commit hash. The owner explicitly authorized retargeting existing PR #837 and force-with-lease after validation and the full retrospective. No further Copilot request is authorized.

The historical Stack 07 commit 4695a11444fa6a3bb990e59d000b8149bc5b74f3 was replayed as 632de4f7f onto the predecessor intake, then reconciled through merges 66dc2df72, 34a36e700, c2c7dc111 and fb6f8e623 onto the latest published Stack 06 head. Its historical base b771669ba842d83790a69b6132f63cea82e5a861 is not the corrective candidate's base. Historical source inventory: 38 files, 10046 additions, 207 deletions. Per-commit file/count provenance is in 715-07-history-20260924.tsv; overlapping history counts must not be summed as the net current diff.

This block adds a bounded authenticated runtime-catalog/ABI/display subset and device-driven streamed EIP-712. Ordinary fully disclosed streamed EIP-712 works without AdvancedMode. Runtime-certified annotations and blind precomputed typed hashes require AdvancedMode. Runtime annotations remain additive to ordinary review and carry explicit source/warning/intent screens. Full ERC-7730 v2 conformance, firmware-trusted registry authority and later stack features are excluded. BTC-only omits these engines.

2. Source reconciliation and behavior coverage

Paths	Prior behavior; candidate behavior; why and evidence
eip712_stream.h/.c and native tests	Adds bounded schema discovery, canonical type/value hashing, visible leaf review and resumable typed signing. Repairs header/count bounds, nested dimensions and schema consistency. Fixed schemas and signed domain constraints survive repeated field walks. Published type-hash vectors, malformed encodings, array/schema negative controls and host repeated-field tests execute these properties.
erc7730_catalog.h/.c and tests	Adds streaming envelope/program validation and runtime-key authentication. Signed identity uses the entire program leaf. Canonical empty root and domain records are supported. Real signature tampering tests refute header/key bypass; source alias is the user-approved runtime alias.
erc7730_abi.h/.c, erc7730_abi_stream.h/.c and tests	Adds bounded recursive canonical ABI parsing. Accepts selector-only root while rejecting malformed graphs; stream owns its program view, eliminating caller-lifetime dependency. Chunk-boundary, offset/padding, caller-view overwrite and extreme-index tests run.
erc7730_program.h/.c, condition, format and tests	Adds bounded section/literal/path/condition/formatter readers. Domain operations are retained across chunks; unsupported shapes and oversized/missing values fail closed. Native typed selection/format and authenticated host fixtures cover execution.
erc7730_workflow.h/.c, erc7730_tx.h/.c and tests	Orchestrates definition replay, capture and signing continuation. SHA-256 binds calldata and typed domain/message digests across all passes; every typed display field advances. Negative controls catch removed commitments; host altered-signing-pass and multi-field fixtures pass.
ethereum.h/.c, fsm_msg_ethereum.h and Ethereum tests	Integrates runtime annotation plus mandatory ordinary review and restores direct chain-ID maximum validation. Adds runtime source/fingerprint/warning/intent on both calldata and typed paths. Real signatures match ordinary signing; decline/mutation paths return no signature.

Paths	Prior behavior; candidate behavior; why and evidence
fsm.c, fsm_msg_common.h and fsm tests	Phase-specific admission for new messages. Accepted continuations preserve active workflow; abort/session boundaries clear EIP-712 and ERC state; valid progress renews auto-lock while polling does not. The final Stack 06 CoinTable capacity raises the response to 24 entries; this head removes that one response from the permanent union and validates/copies its request before reusing decoded-request storage. Actual receive-path timer, session-boundary and 10/24-entry CoinTable tests run.
board messages.h/.c and messagemap.def	Dense message lookup and new full-product protocol registration. The decoded request buffer is exposed only as response scratch for the CoinTable handler after its input fields are copied; normal dispatch clears it on return, and TX encoding uses the separate frame arena. Shared receive/tiny-buffer regressions and real wire CoinTable tests run in both variants; BTC excludes Ethereum handlers.
firmware/unit CMakeLists.txt	Registers all new engines/tests only in the full product. Both native and ARM links pass; both product boundaries are executed.
deps/python-keepkey	Advances the final Stack 06 base pin b745562be to 1d42a1f: correct screenless unlimited-approval report contract and immediate wire Failure assertion. The earlier Stack 07 correction is preserved across the latest Stack 06 merge.
ci.yml and scripts/emulator/python-keepkey-tests.sh	Removes only the now-implemented erc7730-runtime-review staged exclusion. Preserves predecessor's workflow-wide inventory and runs nine Stack 07 contracts in CI. Workflow lint and shell syntax pass.
scripts/emulator/test_stack07_regressions.py	Real signed-envelope, cancellation, source/intent, every-field, domain-substitution and signing-replay regressions, plus a cross-variant CoinTable wire test. Full nine pass; BTC CoinTable passes and eight Ethereum cases intentionally skip. The wire test checks 10/24-entry full pages, two-entry BTC page, invalid-range refusal and recovery.
HANDOFF-ERC7730-ALPHA.md and audit documents	Historical alpha design is clearly labeled; bounded 7.15 contract and actual policy are stated. Intake retains historical failures. Current report, full retro, skip ledger and evidence supersede pending implementation statements in that intake.

3. Findings and security closure

The accompanying 715-07-first-copilot-retrospective-20260924.md/PDF is the complete finding ledger, cross-phase contract table, separate falsification pass and root-cause analysis. It dispositions all 13 inline comments plus the review body: nine fixed comments/eight roots, two overlapping policy corrections, two technical refutations. It also records five additional local/integration defects repaired. The later Stack 06 allowance interaction is closed by early certified-approval refusal; ordinary finite approval remains available. No known in-scope code defect remains after these local checks. GitHub thread closure is recorded in the PR after pushed fixes and individual replies.

The security matrix names host bytes/schema/domain, runtime authority, visible consent, bounds, timers and product separation; it follows them through parsing, replay, OLED and signing. Four deliberately removed protections produce four failing native tests; source bytes are restored and final native tests pass. A green aggregate count is not used as a substitute for these assertions.

4. Executed validation and limits

Check	Result and evidence
Full native	602 firmware, 19 board, 18 crypto and 72 Zcash crypto pass; native-full.xml and board/crypto/zcash-full.xml. Includes inherited allowance and CoinTable capacity tests.
BTC native	135 firmware, 19 board and 18 crypto pass; native-btc.xml and board/crypto-btc.xml.
Full host	739 pass, 92 skip; host-full.xml, with the rebuilt child emulator available for five owned-process storage checks.
BTC host	347 pass, 484 skip; host-btc.xml, with the rebuilt child emulator available for five owned-process storage checks.

Check	Result and evidence
Stack 07 contracts	Nine full-product tests pass; stack07-full.xml. BTC CoinTable passes and eight Ethereum tests deliberately skip; stack07-btc.xml. OLED frames from the prior unchanged annotation implementation in stack07-oled.
Negative controls	Four expected failures in prior-negative-controls.xml/log from the unchanged Stack 07 parser implementation; sources restored byte-for-byte. This predecessor integration adds the independent signed-envelope approval refusal regression, and the merged native suite passes.
ARM/resource	Both MinSizeRel products link after the CoinTable scratch repair. Full reserve 18896 bytes, BTC 39136; largest frame 7664 in both, exceeding the required 4096-byte margin. Exact SRAM budget script passes; sram-full/btc.log and stack-usage archives. The unmodified 24-entry merge failed the 16 KiB full-product linker reserve.
OLED	Runtime alias/fingerprint, NOT verified by KeepKey warning, intent and both typed values visually inspected. Cancellation fixtures cover source, warning, intent and each field; intent-only fixture adds source/intent to ordinary review.
Report/automation	Both combined JUnit SECTIONS validations pass, six validator tests pass, actionlint and shell syntax pass, git diff --check passes. Code-bearing preflight is repeated against the final frozen range.

All 576 broad host skips are named with their actual reasons in 715-07-skips-20260924.tsv. The explicit staged capability list is evm-max-amount-review, evm-unknown-token-review, entropy-audit-budget, osmosis-wire-guards, hive-release-review, storage-v19-kdf, solana-lut-attestation. Those later-block capabilities are not claimed as covered. The ordinary broad suite and focused suites overlap and must not be summed as unique coverage. The first final host invocation used the wrong capability-variable name; its 13 full and one BTC failures are retained as incorrect-env-host-*.xml, then the exact workflow variable was used for the passing results. No assertion was weakened.

Earlier reused-flash/native failures, initial dispatch failures and infrastructure failures are explained in the full retrospective. Physical USB/controller timing, physical OLED/buttons, signed-device upgrade, complete release assembly and promotion remain unverified. The static SRAM gate is not a measured physical high-water mark. Hosted exact-head CI status is recorded separately in the PR, not inferred from local checks. Stack 06 acceptance remains under its owner's claim.

Evidence bundle: 715-07-validation-20260924.tgz; SHA256 manifest: 715-07-validation-sha256-20260924.txt. ARM images are retained externally with hashes, not included in Git. Builder: kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2.

The first corrective hosted run 35962710863 failed full screenshot audit because the unlimited-approval refusal was incorrectly assigned two review frames. All 162 selected wire tests passed (26 skips), and BTC integration passed. Host pin 1d42a1f corrects the report and adds an exact immediate-Failure/no-ButtonRequest assertion. Seven earlier focused tests and the corrected audit against the original hosted frames passed. This prior correction is retained across the final Stack 06 base. See the hosted-qualification section in the full retro.

5. Final Stack 06 predecessor integration

Stack 06 advanced from 8ed653517 to ff956077f with an allowance policy that refuses partial approval prefixes before confirmation and refuses unlimited approvals even when native value or trailing data are present. Those changes merge cleanly. Stack 07's certified transaction starts with selector only, so its prior path could have shown annotation screens before the predecessor's eventual refusal. Candidate 3e2de50b5 refuses the certified approval selector before definition replay or any ButtonRequest and clears the preload. A real signed-envelope host test proves zero screens on the refusal and confirms a finite ordinary full-prefix approval still signs. This bounded subset does not promise certified approval annotation until the full 68-byte prefix can be validated before UI and bound to signing. Three inherited native allowance regressions, the host case, full native/host and ARM/resource checks execute on this merged source.

Stack 06 then advanced to efdeb678bc33c616cf8048fb5773548f0da96fa7 to restore its accepted predecessor's 24-entry CoinTable pages. The unmodified merge failed the full ARM linker's 16 KiB reserve with 15,132 bytes remaining: the permanent response union grew by 3,768 bytes alongside Stack 07's workflow state. Candidate 92774faeb keeps the full 24-entry wire response but stores it in the existing decoded-request buffer after copying and validating the four request fields. The transport is single-threaded; it does not dispatch another normal request until this handler returns, and outbound encoding uses a different frame arena. Compile-time size/alignment checks guard the scratch. Full and Bitcoin-only host tests prove successful pages, invalid-range refusal and recovery; native, broad host, both ARM links and exact SRAM gates pass. This correction belongs to Stack 07's predecessor interaction, not to the separately owned Stack 06 branch.

No issue was hidden by removing a report declaration or skipping a test. The earlier hosted screenshot failure/correction is retained in the retrospective as a separate first-repair event. Stack 06's code-review checkpoint remains separately owned; merging its latest published branch does not claim it accepted.

The first hosted CI attempt on this predecessor, run 36058831515 at 651db1062, stopped at formatting/static analysis. Ubuntu clang-format 20 requires a different pointer-token spelling in the generated union macro than local clang-format 22. Cppcheck 2.13 found redundant bounds conditions and flagged generated union members as unused; the CI shell exited before printing its report because `bash -e` treats the cppcheck nonzero result as terminal. Head 92774faeb matches clang-format 20, adds a compile-time member-size check, and simplifies the already validated request branches. Reproduction with Ubuntu cppcheck 2.13 reports zero findings. Both products rebuild and pass native/focused wire tests; the first failed hosted run is retained in the retro and does not count as a green gate.

6. Pins and adjacent inventory

The only dependency pin change relative to efdeb678bc33c616cf8048fb5773548f0da96fa7 is the BitHighlander Python host b745562be to 1d42a1fa401129da292a8b0fe4f6dc9bee727117, retained from Stack 07's earlier report correction. It contains the screenless-approval report correction and immediate-refusal test. Crypto: 8a392f70a5d5575ece3dfb35f115d4a4b27f497c; protocol: dd9c85dc747cf965fb0e7bf49615dc9e7568ee65; GoogleTest: 7888184f28509dba839e3683409443e0b5bb8948; nested Ethereum list: 89a64f717e1690bb31adb3e4c38e23640357333c. The pin is fetchable from the BitHighlander fork.

Immutable inventory command: `git diff --numstat`

efdeb678bc33c616cf8048fb5773548f0da96fa7..2ea62657693413405e3730fb13c40c1db961191e. Counts include all code, tests, workflows, documents and binary evidence. Binary counts are shown as dashes. The final containing head is in the PR body; inventory/path/count equality is checked after the report commit.

Added	Deleted	Path
1	1	.github/workflows/ci.yml
1	1	deps/python-keepkey
123	0	docs/release/audit-units/715-07-first-copilot-retrospective-20260924.md
-	-	docs/release/audit-units/715-07-first-copilot-retrospective-20260924.pdf
112	0	docs/release/audit-units/715-07-history-20260924.tsv
62	0	docs/release/audit-units/715-07-intake-20260924.md
131	0	docs/release/audit-units/715-07-review-20260924.md
-	-	docs/release/audit-units/715-07-review-20260924.pdf
577	0	docs/release/audit-units/715-07-skips-20260924.tsv
-	-	docs/release/audit-units/715-07-validation-20260924.tgz
112	0	docs/release/audit-units/715-07-validation-sha256-20260924.txt
295	0	docs/security/HANDOFF-ERC7730-ALPHA.md
48	24	include/keepkey/board/messages.h
210	0	include/keepkey/firmware/eip712_stream.h
80	0	include/keepkey/firmware/erc7730_abi.h
81	0	include/keepkey/firmware/erc7730_abi_stream.h
190	0	include/keepkey/firmware/erc7730_catalog.h
20	0	include/keepkey/firmware/erc7730_condition.h
19	0	include/keepkey/firmware/erc7730_format.h
296	0	include/keepkey/firmware/erc7730_program.h
26	0	include/keepkey/firmware/erc7730_tx.h
153	0	include/keepkey/firmware/erc7730_workflow.h
4	8	include/keepkey/firmware/ethereum.h
8	15	lib/board/messages.c
9	0	lib/firmware/CMakeLists.txt
1238	0	lib/firmware/eip712_stream.c
472	0	lib/firmware/erc7730_abi.c
433	0	lib/firmware/erc7730_abi_stream.c
1389	0	lib/firmware/erc7730_catalog.c
101	0	lib/firmware/erc7730_condition.c
196	0	lib/firmware/erc7730_format.c
836	0	lib/firmware/erc7730_program.c
46	0	lib/firmware/erc7730_tx.c
721	0	lib/firmware/erc7730_workflow.c
158	30	lib/firmware/ethereum.c
79	29	lib/firmware/fsm.c
28	15	lib/firmware/fsm_msg_common.h
976	106	lib/firmware/fsm_msg_ethereum.h
9	0	lib/firmware/messagemap.def
7	0	scripts/emulator/python-keepkey-tests.sh
237	0	scripts/emulator/test_stack07_regressions.py
9	0	unittests/firmware/CMakeLists.txt
764	0	unittests/firmware/eip712_stream.cpp
174	0	unittests/firmware/erc7730_abi.cpp
240	0	unittests/firmware/erc7730_abi_stream.cpp
678	0	unittests/firmware/erc7730_catalog.cpp
76	0	unittests/firmware/erc7730_condition.cpp
133	0	unittests/firmware/erc7730_format.cpp
390	0	unittests/firmware/erc7730_program.cpp
74	0	unittests/firmware/erc7730_tx.cpp
203	0	unittests/firmware/erc7730_workflow.cpp
13	0	unittests/firmware/ethereum.cpp
62	2	unittests/firmware/fsm.cpp

7. Render/preflight and review checkpoint

Report source and PDF are frozen together; rendered pages are inspected for readable tables and matching inventory. Final path/count comparison, exact live base/head, code-bearing gate and whitespace check precede any future request. Implemented, targeted, integration and adversarial states are locally verified as listed. One historical external review delivered Changes recommended; this is not a current-head clean review. No second round is requested. The complete retro and pushed thread dispositions must be read before the owner considers another request. This receipt does not mark release acceptance or authorize merging/promoting the product.